

## README: KIT ADAM 2.0 - INDICADORES GQM+PRAGMATIC

### Guía Integral de Uso - Ciberseguridad España

**Versión:** 2.0

**Fecha:** Enero 2026

**Idioma:** Español

**Clasificación:** Uso Estratégico

**Validez:** Enero 2026 - Enero 2027 (requiere revisión anual)

#### CONTENIDO DEL KIT ADAM 2.0

Este Kit contiene **6 documentos profesionales + 2 plantillas ejecutables** para diseñar, implementar y ejecutar una evaluación integral de ciberseguridad alineada a objetivos nacionales (Estrategia Ciberseguridad España 2019 + DSN 2024).

#### Documentos Incluidos

| # | Documento                      | Tipo         | Propósito                                                      | Usuarios          |
|---|--------------------------------|--------------|----------------------------------------------------------------|-------------------|
| 1 | 1-Marco-GQM-PRAGMATIC.md       | Framework    | Alineación objetivos nacionales → métricas + criterios calidad | CISO, Consultores |
| 2 | 2-Matriz-PRAGMATIC-Completa.md | Evaluación   | 25 indicadores calificados bajo 9 criterios PRAGMATIC          | Auditores, GRC    |
| 3 | 3-Mapeo-Normativo-ADAM.md      | Compliance   | Trazabilidad indicadores a NIS2, ISO 27001, GDPR, NIST CSF     | Auditoría legal   |
| 4 | 4-Plantilla-Excel-ADAM.md      | Operacional  | Guía implementación con 8 hojas + 150+ fórmulas                | Analistas datos   |
| 5 | 5-Reporte-Ejecutivo-ADAM.md    | Presentación | Template PowerPoint 12 diapositivas                            | Ejecutiva, Junta  |
| 6 | 6-README.md                    | Este archivo | Guía uso + roadmap implementación                              | Todos             |

## Archivos Ejecutables Complementarios

- ADAM\_IGM\_Calculator\_v2.0.xlsx → Plantilla Excel completa (descargable)
- ADAM\_Reporte\_Ejecutivo\_v2.0.pptx → Template PowerPoint (descargable)

## CASOS DE USO PRINCIPALES

### UC1: Auditoría Interna de Postura Ciberseguridad (TRIMESTRAL)

**Audiencia:** CISO, Responsable GRC, Auditores Internos

**Frecuencia:** Q1, Q2, Q3, Q4

**Esfuerzo:** 3-4 semanas (80 horas)

**Salida:** IGM Score + Trend Report

#### Proceso:

1. Rellenar 25 indicadores ADAM (Hoja 1 Excel)
  - └ Entrada manual: CISO, Presupuesto, Histórico
  - └ Entrada auto: CMDB, SIEM, ITSM, Phishing platform
2. Sistema auto-calcula IGM (Hoja 3-4)
  - └ Conversión a escala 0-5
  - └ Ponderación por dominio
  - └ Maturity Level + Riesgo Residual %
3. Análisis gaps vs. benchmark (Hoja 7)
  - └ Comparativa sectorial
  - └ Identificación prioridades
  - └ Roadmap 90 días
4. Presentación Ejecutiva (5 diapositivas)
  - └ Junta/Comité de seguridad
  - └ Decisión: Inversión/Acciones

**Resultado:** IGM trending, detección temprana degradación

### UC2: Business Case de Inversión Ciberseguridad (ANUAL)

**Audiencia:** CFO, Directiva, Junta

**Cuando:** Solicitar presupuesto anual

**Esfuerzo:** 2 semanas (40 horas)

**Salida:** ROI proyectado + Roadmap 18 meses

#### Proceso:

1. Baseline: Medir IGM estado actual (semana 1)
2. Escenarios FAIR (Hoja 5-6 Excel)
  - └ ALE actual (sin mejoras): €3M/año
  - └ ALE post-iniciativas (SIEM, MFA, etc): €1.2M/año
  - └ Beneficio neto: €1.8M/año reducción riesgo
3. Proyectar ROI por iniciativa
  - └ SIEM: €300k inversión → €500k/año beneficio (ROSI 167%)
  - └ MFA: €60k → €78k/año beneficio (ROSI 131%)
  - └ Roadmap total: €800k → €2.1M beneficio 3 años (ROSI 563%)
4. Presentar CFO + Junta
  - └ 3 diapositivas (contexto + ROI + decisión)
  - └ Objetivo: Aprobación presupuesto

**Resultado:** Presupuesto justificado con números, no conjeturas

### UC3: Auditoría Externa / Cumplimiento Regulatorio (ANUAL)

**Auditor Externo:** Firma Big 4, Deloitte, KPMG, etc.

**Regulaciones:** NIS2, ISO 27001, GDPR, ENS

**Esfuerzo:** 4 semanas (incluye auditor)

**Salida:** IGM Certificado + Certificación/Gaps Findings

#### Proceso:

1. Organización rellena pre-encuesta ADAM
  - └ Datos brutos antes auditoría
2. Auditor externo:
  - └ Valida entrada de datos vs. evidencia documental
  - └ Accede a CMDB, SIEM, ITSM para verificación
  - └ Usa Mapeo Normativo para alinear a requisitos específicos
  - └ Genera IGM auditado (independiente, vinculante)
3. Salida final:
  - └ Certificación: "IGM auditado 2.92/5.0" (con sello)
  - └ Gaps encontrados con priorización
  - └ Recomendaciones timeline remediación

**Resultado:** Auditoría con métricas objetivas; no subjetivas

### UC4: Benchmarking Competitivo / Due Diligence (SEMESTRAL)

**Casos:** Comparar vs. competencia, Evaluación inversores, Merger & Acquisition

**Esfuerzo:** 1 semana

**Salida:** Score comparable, Análisis competitivo

#### Proceso:

1. Recopilar IGM de 5-10 organizaciones similares
2. Calcular percentil posición propia
3. Análisis brecha vs. líderes sector
4. Benchmark público (anónimo) para comunicación

**Resultado:** Posicionamiento competitivo demostrable

### UC5: Evaluación Supply Chain / Riesgo Proveedores (ANUAL)

**Audiencia:** Procurement, Risk Management

**Aplicación:** Proveedores críticos (nivel 1)

**Esfuerzo:** 2-3 semanas

**Salida:** Risk Score proveedores + Matriz mitigación

#### Proceso:

1. Enviar Encuesta Simplificada a proveedores (15 preguntas clave)
2. Recopilar IGM terceros:
  - └ Proveedor A: IGM 3.2 (ACEPTABLE)
  - └ Proveedor B: IGM 2.1 (RIESGO)
  - └ Proveedor C: IGM 4.0 (BUENO)
3. Matriz Riesgo:
  - └ IGM <2.5 → Alto riesgo → Acción: Auditoría externa
  - └ IGM 2.5-3.5 → Riesgo medio → Monitoreo trimestral
  - └ IGM >3.5 → Bajo riesgo → Monitoreo anual
4. Integrar en contratación:
  - └ "Cláusula ciberseguridad: Mín IGM 2.5 anual"

**Resultado:** Riesgo supply chain cuantificado, mitigable



### ESTRUCTURA TEMPORAL IMPLEMENTACIÓN

#### Fase 0: PREPARACIÓN (Semana 1)

| Tarea                            | Responsable      | Horas | Deliverable        |
|----------------------------------|------------------|-------|--------------------|
| Nombrar CISO/GRC propietario     | CEO              | 1h    | Acta designación   |
| Revisar 6 documentos del Kit     | CISO + Consultor | 4h    | Notas alineación   |
| Identificar stakeholders         | CISO             | 2h    | Lista distribución |
| Crear drive compartido           | IT               | 1h    | Acceso repositorio |
| Presupuestar: €5-10k consultoría | CFO              | 1h    | Aprobación inicial |
| TOTAL                            |                  | 9h    | Kickoff listo      |

### Fase 1: RELLENAR ENCUESTA (Semanas 2-4)

| Tarea                                        | Responsable     | Horas | Deliverable              |
|----------------------------------------------|-----------------|-------|--------------------------|
| Sesión formación GQM+PRAGMATIC               | Consultor       | 4h    | Capacitación completada  |
| Dividir en equipos por sección               | CISO            | 2h    | Asignaciones claras      |
| Recopilar datos indicadores (20 automáticos) | IT/SIEM/ITSM    | 16h   | Hoja 1 completada        |
| Validar respuestas vs. evidencia             | Auditor Interno | 12h   | Matriz validación        |
| Sesión gaps + consenso                       | CISO + Equipos  | 4h    | Resolución discrepancias |
| TOTAL                                        |                 | 38h   | Encuesta validada        |

### Fase 2: CÁLCULO + ANÁLISIS (Semana 5)

| Tarea                           | Responsable | Horas | Deliverable            |
|---------------------------------|-------------|-------|------------------------|
| Importar datos a Excel          | Analista    | 2h    | Hoja 1 → 2             |
| Auto-calcular IGM               | Sistema     | 0.5h  | Hoja 3-4 generado      |
| Validar no errores (spot check) | Analista    | 2h    | Checklist completado   |
| Generar Radar NIST CSF          | Sistema     | 0.5h  | Visualización generada |
| Análisis gaps vs. benchmark     | Consultor   | 4h    | Matriz priorización    |
| TOTAL                           |             | 9h    | IGM + Dashboard listo  |

### Fase 3: ROADMAP + FINANCIERO (Semana 6)

| Tarea                        | Responsable      | Horas | Deliverable         |
|------------------------------|------------------|-------|---------------------|
| Definir Q1-Q6 iniciativas    | CISO + Consultor | 8h    | Propuesta roadmap   |
| Calcular FAIR + ALE          | Consultor FAIR   | 6h    | Análisis riesgo €   |
| Proyectar ROI por iniciativa | Analista         | 4h    | Hoja 6 completa     |
| Estimar IGM post-iniciativas | Consultor        | 2h    | Trajectory IGM 18m  |
| TOTAL                        |                  | 20h   | Business case listo |

#### Fase 4: PRESENTACIÓN EJECUTIVA (Semana 7)

| Tarea                    | Responsable  | Horas        | Deliverable                 |
|--------------------------|--------------|--------------|-----------------------------|
| Preparar 12 diapositivas | Comunicación | 8h           | PowerPoint draft            |
| Validación CISO + CFO    | CISO, CFO    | 2h           | Aprobación contenido        |
| Ensayo + Q&A prep        | CISO         | 2h           | Readiness meeting           |
| Presentación a Junta     | CISO         | 1.5h         | Sesión completada           |
| <b>TOTAL</b>             |              | <b>13.5h</b> | <b>Decisión documentada</b> |

**RESUMEN TOTAL FASE 1:** 89.5 horas ≈ 11-12 semanas (3 meses)

#### HERRAMIENTAS REQUERIDAS

##### Software Mandatorio

- Microsoft Excel 2016+ o Google Sheets (para Plantilla Excel)
- PowerPoint 2016+ o Google Slides (para Reporte Ejecutivo)
- Adobe PDF Reader (para leer documentos .md como PDF)

##### Herramientas Internas Requeridas (para extracción datos)

| Herramienta        | Datos Extracto                        | Indicadores              |
|--------------------|---------------------------------------|--------------------------|
| CMDB / ITSM        | Inventario activos, histórico cambios | #6: Cobertura inventario |
| VM (Qualys/Nessus) | Scan reports, CVSS scores             | #7-8: Vulnerabilidades   |
| SIEM               | Eventos, timestamps alertas           | #19: MTTD, #21: Falsos+  |
| ITSM Tickets       | Ciclo vida tickets remediación        | #10: Ciclo vuln          |
| Phishing Platform  | Simulación resultados                 | #17: Click rate          |
| Backup Tool        | Logs ejecución, RPO/RTO               | #26-28: Backup metrics   |
| MFA System         | Adoption adoption rate                | #14: MFA universal       |
| LMS                | Compleitud cursos                     | #18: Capacitación %      |

##### Herramientas Opcionales (recomendadas)

- Tableau / Power BI (visualización dashboards avanzados)
- FAIR-U Software (cálculo FAIR automatizado)
- Nuestra plantilla Excel completa (descargable, lista para usar)

#### CHECKLIST PRE-IMPLEMENTACIÓN

Antes de comenzar Fase 1, verificar:

- [ ] CISO designado como propietario proyecto
- [ ] Acceso a todos 6 documentos .md del Kit
- [ ] Plantilla Excel descargada (versión 2.0)
- [ ] Stakeholders identificados + calendarios reservados
- [ ] Acceso a CMDB, SIEM, ITSM confirmado
- [ ] Presupuesto €5-10k consultoría aprobado
- [ ] Drive compartido + distribución permisos completada
- [ ] Sesión kickoff programada (semana 1)
- [ ] Aval de CFO para tiempo/recursos asignados

## **PRÓXIMOS PASOS**

### **Inmediatos (Esta Semana)**

1. Descargar 6 documentos + 2 plantillas
2. Revisar Documento 1 (Marco GQM+PRAGMATIC)
3. Designar CISO como propietario
4. Contactar consultor ciberseguridad (si no hay interno)

### **Corto Plazo (Próximas 2 Semanas)**

5. Sesión kickoff con equipo (presentar Framework)
6. Acceso sistemas (CMDB, SIEM, ITSM)
7. Dividir trabajo por equipos

### **Mediano Plazo (Próximas 12 Semanas)**

8. Ejecutar Fases 1-4 (89.5 horas)
9. Obtener aprobación presupuesto
10. Comenzar Roadmap Q1 (Quick Wins)

## **SOPORTE Y PREGUNTAS FRECUENTES**

### **P1: "¿Cuánto cuesta implementar ADAM 2.0?"**

**R:** Depende de si usan consultor externo:

- **Interno (solo CISO/GRC):** Tiempo (89 horas), Software €0-200
- **Con consultor externo:** €8-15k + tiempo interno
- **Auditoría externa (ISO/NIS2):** €20-50k adicional

### **P2: "¿Qué diferencia ADAM 2.0 vs. ADAM v1.0?"**

**R:**

- v1.0: 50 preguntas abiertas, métrica inicial
- v2.0: **GQM + PRAGMATIC**, 25 indicadores con rigor metodológico, validación externa

### P3: "¿Podemos customizar los indicadores?"

**R:** Sí, pero con cuidado:

- Las 25 métricas están validadas para cobertura NIST CSF 100%
- Agregar métricas: Validar contra 9 criterios PRAGMATIC
- Remover: Verificar no quedan gaps regulatorios

### P4: "¿Puedo compartir IGM públicamente?"

**R: NO recomendado.** IGM revela vulnerabilidades:

- Publicación = información de inteligencia para atacantes
- Máximo: Benchmarking anónimo (no mencionar nombre org)
- Auditoría: Bajo NDA, confidencial

### P5: "¿Con qué frecuencia actualizar IGM?"

**R:**

- **Operacionales (MTTD, Falsos+):** Mensual (dashboards)
- **Indicadores tácticos (Vuln, Parches):** Trimestral
- **IGM completo:** Trimestral (reporte) o anual (auditoría)
- **Benchmarking:** Semestral (o anual si recursos)



## LICENCIA Y USO

**Licencia:** Creative Commons CC-BY-SA 4.0

### Uso Permitido:

-  Uso interno organizacional (ilimitado)
-  Adaptaciones para contexto local/sector
-  Compartir con auditores/consultores bajo NDA
-  Citación y referencia académica

### Uso NO Permitido:

-  Vender/comercializar sin atribución
-  Remover referencias al original
-  Usar para marketing sin consentimiento



## RECURSOS ADICIONALES

### Frameworks de Referencia

- NIST CSF 2.0: <https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf>
- ISO/IEC 27001:2022: <https://www.iso.org/standard/27001>
- Directiva NIS2 (2022/2555): <https://eur-lex.europa.eu/eli/dir/2022/2555/oj>
- ENS 2.0 (España): <https://www.ccn.cni.es/>



## Herramientas Correlacionadas

- GQM Framework: Goal-Question-Metric (Basili & Weiss, 1984)
- PRAGMATIC Criteria: Glasgow et al., 2013; PRECIS-2 Tool
- FAIR Analysis: FAIR Institute (Open Group)
- Benchmarking: ISMS Forum, CIS Benchmarks, EU-CSI

## Webinars / Capacitación

- Próximo webinar: "GQM+PRAGMATIC en Práctica" (Febrero 2026)
- Email para registro: [contacto]



## EVOLUCIÓN DEL KIT

### Roadmap de Actualizaciones

| Versión | Fecha    | Cambios                                           |
|---------|----------|---------------------------------------------------|
| v1.0    | Mar 2024 | Lanzamiento inicial (50 preguntas)                |
| v2.0    | Ene 2026 | GQM+PRAGMATIC, 25 indicadores, rigor metodológico |
| v2.1    | Jul 2026 | Post-transposición NIS2 (ajustes si necesario)    |
| v3.0    | Ene 2027 | Integración IA/ML, automatización completa        |



## CONCLUSIÓN

**ADAM 2.0** es más que una encuesta. Es un **framework riguroso** que conecta:

- ✓ **Objetivos nacionales** (Estrategia DSN)
- **Preguntas estratégicas** (GQM nivel 2)
- **Métricas operacionales** (GQM nivel 3)
- **Criterios de calidad** (PRAGMATIC 9 criterios)
- **Requisitos regulatorios** (NIS2, ISO, GDPR)
- **Decisiones financieras** (ROI cuantificado)

**Próximo paso:** Descargar documentos, designar propietario, y comenzar Fase 0.

*Kit desarrollado por Consorcio de Científicos de Datos, Estrategas de Ciberseguridad y Auditores  
Enero 2026 / Versión Profesional / Distribuya responsablemente*